

D-SGSI-04: Metodología de Evaluación y Tratamiento de Riesgos de Seguridad de la Información

Universidad Nacional del Centro del Perú (UNCP)

SGSI ISO/IEC 27001:2022

Organización: Universidad Nacional del Centro del Perú (UNCP) **Versión:** 1.0 **Norma:** ISO/IEC 27001:2022 (Cláusula 6.1.2 y 6.1.3)

1. Objetivo

Establecer el marco metodológico sistemático para identificar, analizar, evaluar y tratar los riesgos de seguridad de la información que puedan afectar la confidencialidad, integridad y disponibilidad de los activos de la UNCP.

2. Alcance

Esta metodología se aplica a todos los procesos, sistemas (ej. ERP ADESA, Campus Virtual) e infraestructura tecnológica detallados en el alcance del SGSI de la UNCP.

3. Frecuencia de Evaluación

La evaluación de riesgos se realizará: * De forma planificada, al menos una vez al año. * Cuando ocurran cambios significativos en la infraestructura tecnológica (ej. migración a Huawei Cloud). * Después de un incidente de seguridad grave (ej. brecha de datos). * Al implementar nuevos proyectos del PGTD (ej. Portal de Servicios Digitales).

4. Fases de la Metodología

Fase 1: Identificación de Activos

Se utilizará el **R-SGSI-03: Inventario de Activos de Información** para listar los activos críticos. Se identificará al “Dueño” de cada activo.

Fase 2: Identificación de Riesgos

Para cada activo, se identificarán los riesgos asociados considerando: * **Vulnerabilidades:** Debilidades del activo (ej. software desactualizado, falta de cifrado). * **Amenazas:** Causas potenciales de un incidente (ej. ataque ransomware, falla eléctrica, error humano).

Fase 3: Análisis de Riesgos

El análisis se realizará calculando el Nivel de Riesgo (NR) mediante la combinación de la **Probabilidad de Ocurrencia (O)** y el **Impacto (I)**.

Fórmula: $NR = O \times I$

3.1. Escala de Ocurrencia (Probabilidad)

Valor	Nivel	Descripción
1	Baja	Es muy poco probable que la amenaza se materialice (ej. 1 vez cada 5 años).
2	Media	Es posible que la amenaza se materialice (ej. 1 vez al año).
3	Alta	Es muy probable que la amenaza se materialice (ej. 1 vez al mes).
4	Muy Alta	Es casi seguro que la amenaza se materialice (ej. diariamente).

3.2. Escala de Impacto (Consecuencia) Se evaluará el impacto sobre la Confidencialidad, Integridad y Disponibilidad (CID). Se tomará el valor más alto de los tres. | Valor | Nivel | Descripción (Ejemplo para la UNCP) | | :— | :— | :— | | 1 | Menor | Interrupción breve de servicios no críticos. Sin pérdida de datos. | | 2 | Moderado | Interrupción temporal del ERP o Campus Virtual (< 4 hrs). Afectación a procesos internos. | | 3 | Significativo | Fuga de datos personales, interrupción de matrícula, impacto a la imagen institucional. | | 4 | Catastrófico | Pérdida total de bases de datos, paralización prolongada de la universidad, sanciones de SUNEDU/Autoridad Nacional de Protección de Datos Personales. |

Fase 4: Evaluación de Riesgos (Matriz de Riesgos)

El Nivel de Riesgo (NR) se determina multiplicando Ocurrencia por Impacto ($NR = O \times I$).

Nivel de Riesgo (NR)	Puntuación	Acción Requerida
Bajo	1 - 4	Riesgo Aceptable. Mantener controles actuales.
Medio	5 - 8	Requiere tratamiento planificado.
Alto	9 - 12	Requiere tratamiento urgente.
Crítico	13 - 16	Intolerable. Acción inmediata por parte del CGD.

Criterio de Aceptación del Riesgo: La UNCP acepta convivir con riesgos cuyo Nivel de Riesgo sea **Bajo (1 a 4)**. Cualquier riesgo con un valor de 5 o superior debe tener un plan de tratamiento.

Fase 5: Tratamiento de Riesgos

Para cada riesgo no aceptable ($NR \geq 5$), el dueño del riesgo seleccionará una de las siguientes opciones de tratamiento:

1. **Mitigar (Modificar):** Aplicar controles de seguridad (del Anexo A de ISO 27001) para reducir la probabilidad o el impacto. (Es la opción más común).
2. **Evitar (Evadir):** Eliminar la causa del riesgo, por ejemplo, cancelando un proceso o desactivando un sistema vulnerable.
3. **Transferir (Compartir):** Trasladar el impacto financiero o de gestión a un tercero (ej. contratar un seguro cibernético, tercerizar en Huawei Cloud con SLAs estrictos).
4. **Aceptar (Retener):** Aceptar el riesgo conscientemente (solo si el costo de mitigación supera el impacto y es aprobado por el Rectorado).

Fase 6: Declaración de Aplicabilidad (SoA)

Los controles seleccionados en la fase de mitigación se documentarán en el **D-SGSI-05: Declaración de Aplicabilidad (SoA)**, justificando su inclusión y su estado de implementación.

5. Documentos Relacionados

- R-SGSI-01: Matriz de Evaluación y Tratamiento de Riesgos (Plantilla Excel).

- R-SGSI-02: Plan de Tratamiento de Riesgos.
- D-SGSI-05: Declaración de Aplicabilidad (SoA).